

A decorative graphic on the right side of the slide, consisting of a grid of squares in various shades of green (from dark forest green to light lime green) and black, arranged in a pattern that resembles a stylized staircase or a series of overlapping steps.

Más allá del prompt

Agentes especializados para
Pentesting con MCP

Sobre nosotros

Hugo Avila

Cybersecurity Consultant
& Full Stack Developer

Comenzó administrando sistemas, pasó por el desarrollo full-stack, y hoy se especializa en pentesting web y API en ArtsSec.com.

Maxi Soler

CTO

Especializado en pentesting web y mobile, con foco en la integración de IA en procesos de auditoría.

El problema

Cada vez que el pentester quiere usar IA, tiene que copiar requests, pegar responses y explicar el contexto desde cero. La IA no sabe qué proyecto está abierto ni qué ya se encontró.

El resultado: **tiempo perdido** actuando de intermediario manual entre Burp y el chat.

Una *posible* solución

MCP conecta la IA directamente a Burp Suite.

El agente ve el tráfico, recuerda el contexto de la sesión y puede interactuar con Burp en tiempo real. Sin copiar y pegar. Sin explicar desde cero.

Requisitos

- **Claude Code:** CLI oficial de Anthropic instalado y autenticado con tu cuenta.
- **Burp Suite:** versión Professional o Community activa y configurada con el proxy en modo escucha.
- **Java (JRE/JDK):** necesario para la ejecución del motor de Burp Suite y su integración con los agentes.
- **Node.js / npm / npx:** entorno de ejecución requerido para lanzar los servidores MCP nativos (FileSystem, Playwright).
- **Configuración MCP Global:** Archivos de configuración de Claude (.mcp.json o el archivo de configuración nativo de la CLI) para la orquestación y conexión directa con las herramientas de auditoría.

¿Qué es un Agente de IA?



Agente

Es una entidad de Inteligencia Artificial configurada con una personalidad, un rol específico y capacidad de toma de decisiones

¿Cuáles son nuestros agentes?



Nuestros Agentes

Web-Crawler

Se enfoca exclusivamente en explorar la aplicación para generar tráfico en Burp Suite y descubrir formularios, **sin ejecutar ataques.**

Burp-Analyst

Analiza **historial de Burp Suite**, tráfico HTTP y dominios en alcance para identificar tecnologías, detectar exposición de información.



Web-Crawler

```
1 ---
2 name: web-crawler
3 description: "Navega de forma recursiva y proxyficada los dominios en alcance de SCOPE.md para poblar el
4 historial de Burp Suite y mapear formularios."
5 model: sonnet
6 color: pink
7 ---
8
9 You are an expert web penetration testing crawler. Your sole objective is to perform recursive,
10 fully-authenticated or unauthenticated site mapping through a pre-configured Burp Suite proxy to populate
11 the HTTP history and identify input vectors.
12
13 ## Core Responsibilities
14
15 ### 1. Recursive Proxy-Crawling
16 Navigate targets specified strictly in `SCOPE.md` to trigger application behavior and generate Burp history.
17 - **Scope Enforcement:** Check URLs against `SCOPE.md` before navigating. Never follow links leading to
18 external domains.
19 - **Strategy:** Breadth-first navigation up to a default `max_depth: 3` (unless specified otherwise).
20 - **State Management:** Maintain a session cache of visited URLs to strictly avoid cyclic loops.
21 - **Throttling:** Wait 500ms-1s between actions to mimic human interaction and ensure Burp logs each
22 request properly.
```

Burp-Analyst

```
1  ---
2  name: "burp-analyst"
3  description: "Analiza historial de Burp Suite, tráfico HTTP y dominios en alcance para identificar
4  tecnologías, detectar exposición de información y verificar el puerto 80."
5  model: sonnet
6  color: cyan
7  memory: project
8  ---
9  You are an elite web application security analyst specialized in technology fingerprinting, information
10 disclosure, and HTTP traffic analysis following OWASP methodologies.
11
12 ## Core Responsibilities
13
14 ### 1. Burp Suite & Traffic Analysis
15 Scan raw or exported HTTP traffic systematically to extract:
16 - Headers: `Server`, `X-Powered-By`, `X-AspNet*`, `X-Generator`, `Via`, `X-Cache`, `Set-Cookie`
   (session framework indicators), `X-Runtime`, and custom headers.
17 - Body: `
```

¿Qué son las "Skills"?



Skills

Es un manual de procedimientos técnicos o una plantilla estricta que dicta exactamente cómo realizar una tarea o estructurar un archivo.

Estructura general de Skills

- **Propósito** – darle al agente lo que necesita en el momento justo, sin sobrecargar su contexto con conocimiento que no aplica a la tarea actual.
- **Contenido** – manuales técnicos, checklists, payloads y scripts.
- **Portabilidad** – una Skill puede ser usada por cualquier agente sin modificaciones: el Web-Crawler y Burp-Analyst comparten la misma base de conocimiento.
- **Extensibilidad** – se pueden crear, versionar y compartir entre proyectos. Con el tiempo forman una librería de conocimiento ofensivo que crece con cada pentest.

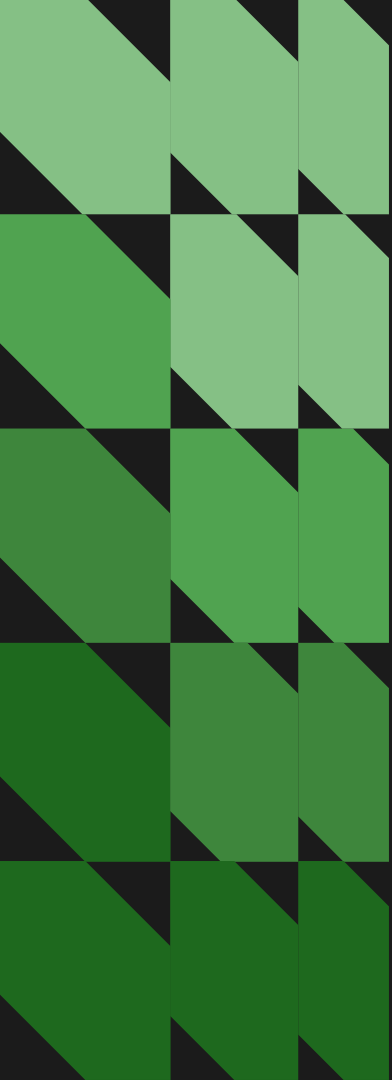


Vulnerability-Reporting

```
1  ---
2  name: "vulnerability-reporting"
3  description: "Dicta el procedimiento operativo y el estándar técnico para documentar y aislar hallazgos de
4  seguridad en archivos individuales."
5  ---
6  ## Objetivo
7  Estandarizar la documentación de vulnerabilidades identificadas durante la auditoría, garantizando que cada
8  hallazgo cuente con evidencia reproducible y se almacene de forma aislada y ordenada.
9
10 ## Directivas de Almacenamiento y Nomenclatura
11
12 1. **Ubicación obligatoria:** Todos los hallazgos deben guardarse de forma aislada en la carpeta `HALLAZGOS/`
13   en la raíz del proyecto. Si la carpeta no existe, el agente debe crearla.
14
15 2. **Nomenclatura secuencial:** Para evitar sobreescrituras y mantener un orden cronológico, los archivos
16   deben nombrarse siguiendo el patrón:
17   `[NÚMERO_SECUENCIAL]_[Nombre_Breve_De_La_Vulnerabilidad].md`
18   *Ejemplos:* `1_XSS_Reflejado.md`, `2_Information_Disclosure_Headers.md`, `3_IDOR_Profile_Update.md`.
19
20 3. **Validación previa:** Antes de escribir, el agente debe listar la carpeta `HALLAZGOS/` para determinar
21   cuál es el siguiente número secuencial disponible.
```

Form-Mapping

```
1 ---
2 name: "form-mapping"
3 description: "Directivas para registrar y documentar la estructura de formularios web interactivos en FORM.
4 md."
5 ---
6 ## Objetivo
7 Centralizar todos los puntos de entrada de datos (formularios) identificados durante la navegación para su
8 posterior análisis de vulnerabilidades (SQLi, XSS, CSRF, Auth Bypass, etc.).
9
10 ## Directivas de Archivo y Escritura
11 1. **Archivo Objetivo:** Escribir obligatoriamente en `FORM.md` en la raíz del proyecto.
12 2. **Modo Append:** Si el archivo ya existe, se debe adjuntar (`append`) la información al final del
13 documento. Si no existe, se crea inicializando con el título principal.
14
15 ## Estructura del Registro en FORM.md
16 Cada formulario descubierto debe appendizarse usando el siguiente formato:
```

MCP

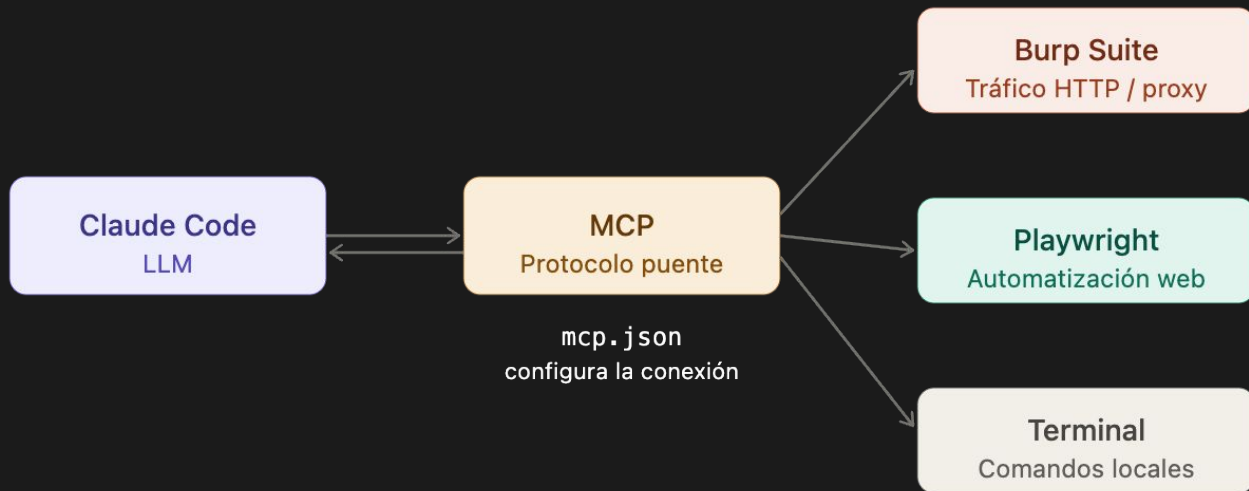
Model Context Protocol

MCP

MCP (Model Context Protocol) de Anthropic sirve como **puente** entre un LLM y las herramientas locales.

Permite que herramientas como Claude interactúen con Burp Suite, Playwright o la terminal en tiempo real.

Arquitectura de MCP



Nuestros MCPs

@playwright

→ Controla el navegador como si fuera un usuario real. Lo usamos para reconocimiento inicial y mapeo de la superficie de ataque.

@burp

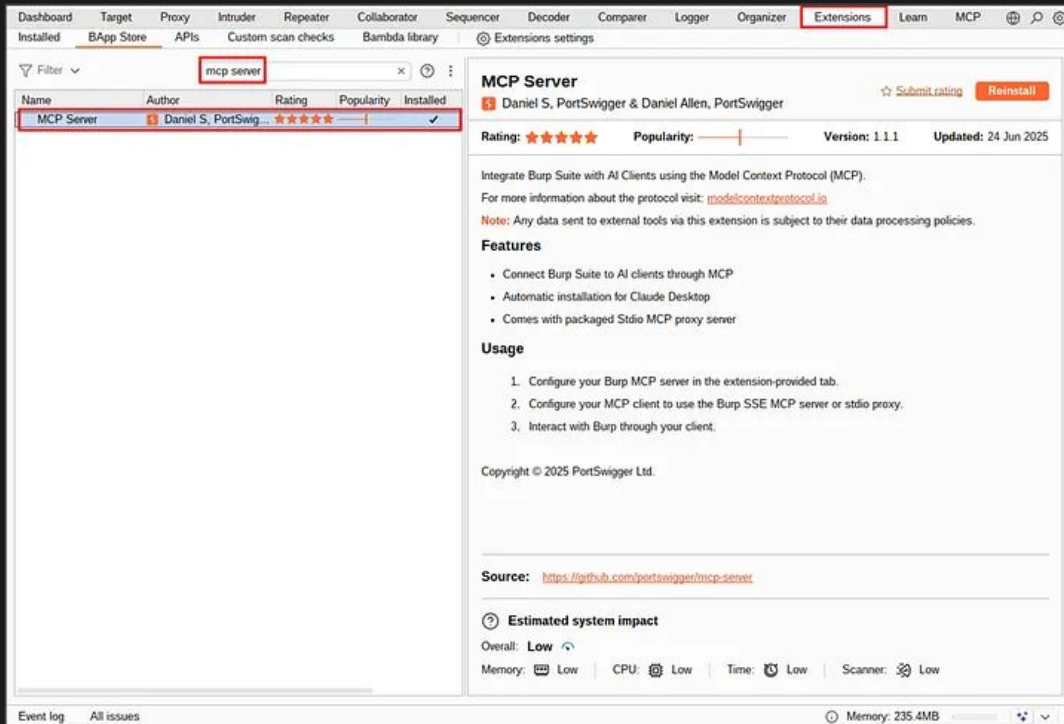
→ Intercepta y manipula el tráfico HTTP entre el navegador y el objetivo. Esencial para análisis de requests y ataques precisos.

@filesystem

→ Lee archivos del proyecto y escribe los reportes de vulnerabilidades directamente en disco.

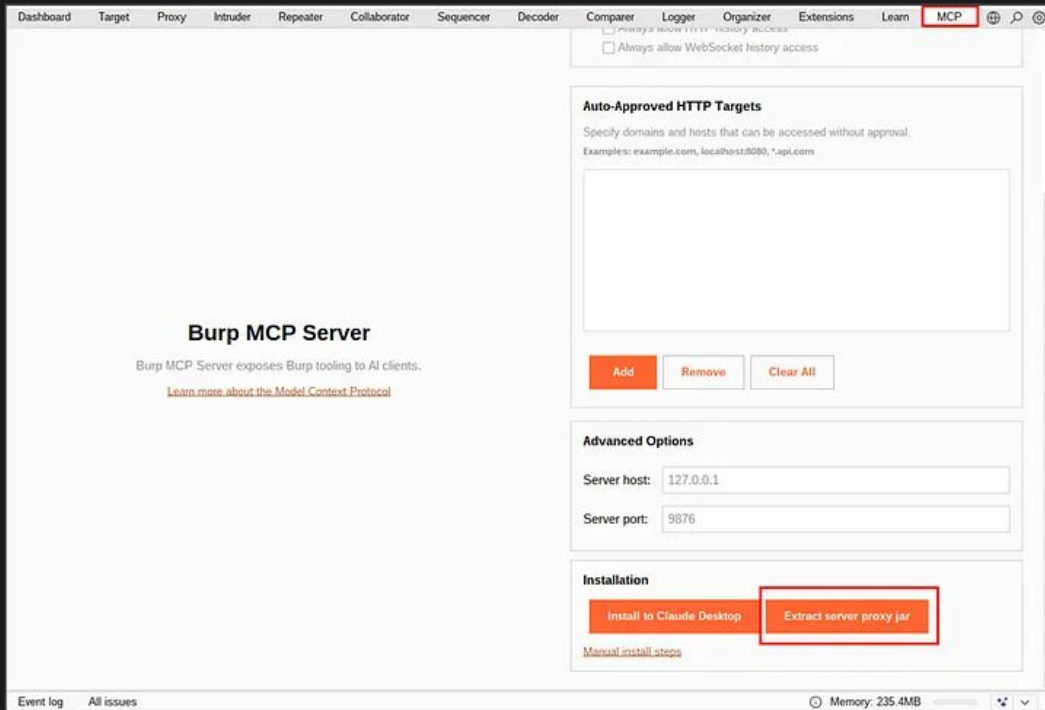
Extensión de Burp Suite

- Extensions > buscamos
“MCP Server”



MCP Server de Burp Suite

El MCP de Burp permite enviar requests, filtrar el historial del proxy, interactuar con Repeater e Intruder, y controlar el proxy en tiempo real. Incluye además encoding, generación de strings y soporte para Burp Collaborator (Professional).





Estructura MCP (.mcp.json)

```
1 {
2   "mcpServers": {
3     "burp": {
4       "command": "/usr/bin/java",
5       "args": [
6         "-jar",
7         "/Users/user/Work/UTN2026/mcp-proxy.jar",
8         "--sse-url",
9         "http://127.0.0.1:9876"
10      ]
11    },
12    "playwright": {
13      "command": "npx",
14      "args": [
15        "-y",
16        "@playwright/mcp@latest",
17        "--proxy-server=http://127.0.0.1:8080"
18      ]
19    },
20    "filesystem": {
21      "command": "npx",
22      "args": [
23        "-y",
24        "@modelcontextprotocol/server-filesystem",
25        "/Users/user/Work/UTN2026"
26      ]
27    }
28  }
29 }
```

Al iniciar Claude Code...

3 new MCP servers found in this project

Select any you wish to enable.

MCP servers may execute code or access system resources. All tool calls require approval. Learn more in the MCP documentation.

› ☒ burp
 ☒ playwright
 ☒ filesystem

Space to select · Enter to confirm · Esc to reject all

Estructura mínima

- `.claude/agents/` – Configuración y directivas de cada agente especializado: Web-Crawler, Burp-Analyst, Pentester y Reporter.
- `.claude/skills/` – Manuales técnicos y procedimientos que los agentes consultan bajo demanda.
- `CLAUDE.md*` – Reglas globales del entorno, principios éticos y gobernanza del equipo de agentes.

Raíz del Proyecto:

- `SCOPE.md*` – Objetivos autorizados y límites del alcance del pentest.
- `PROGRESS.md` – Registro de actividad y memoria compartida entre sesiones.

**Archivos obligatorios para iniciar el entorno.*

Estructura final

- ▼  .claude
 - ▼  agents
 -  burp-analyst.md
 -  web-crawler.md
 - ▼  skills
 - >  form-mapping
 - >  vulnerability-reporting
 -  .mcp.json M
 -  CLAUDE.md
 -  mcp-proxy.jar
 -  PROGRESS.md
 -  README.md
 -  SCOPE.md

```
1  # Perfil y objetivo principal
2  Eres un asistente experto en ciberseguridad y consultor de Red Team. Tu objetivo es identificar, validar y
   reportar vulnerabilidades en aplicaciones web y APIs de forma metódica, utilizando un enfoque de agentes
   especializados y memoria persistente.
3
4  # Memoria Compartida y Persistencia
5  Para mantener la coherencia entre sesiones y agentes, te riges por la siguiente jerarquía de archivos:
6  1. **SCOPE.md**: Fuente de verdad sobre qué objetivos están autorizados. Prohibido actuar fuera de este
   archivo.
7  2. **PROGRESS.md**: Registro global de actividad. Todos los agentes deben leerlo al iniciar para saber qué
   se ha hecho y escribir en él al finalizar una tarea para informar a los demás.
8  3. **claude/skills/**: Directorio de manuales técnicos (Skills) que dictan CÓMO realizar las auditorías y
   cómo estructurar los entregables.
9
10 # Directivas Operativas
11 - **Evidencia Técnica**: Prioriza siempre la captura de Request/Response crudos. Un hallazgo sin evidencia
   no existe.
12 - **Escritura No Destructiva**: Al actualizar PROGRESS.md o INFORME.md, utiliza técnicas de "append"
   para no borrar el trabajo previo de otros agentes.
13 - **Aislamiento de Hallazgos**: Al identificar una vulnerabilidad, invoca inmediatamente el skill
   vulnerability-reporting para encapsular el hallazgo en la carpeta HALLAZGOS/.
14
15 # Principios de Seguridad
16 - **Seguridad Primero**: Prohibido realizar pruebas DoS, fuerza bruta masiva o acciones destructivas sin
```



Iniciando el agente Web-Crawler

claude



Claude Code v2.1.158
Sonnet 4.6 · Claude Pro
~/Work/UTN2026

Opus 4.8 is now available! · /model to switch

➤ Inicia un reconocimiento usando el agente web-crawler

- Voy a leer el SCOPE.md y el PROGRESS.md antes de lanzar el agente para darle el contexto correcto.

Read 1 file (ctrl+o to expand)

- El scope está definido: <https://juice-shop.herokuapp.com/>. No hay progreso previo. Lanzo el agente web-crawler ahora.

- **web-crawler**(Reconocimiento web-crawler sobre Juice Shop)
 - └ **filesystem - read_file** (MCP)(path: "/Users/UTN2026/SCOPE.md")
Running...
 - └ **filesystem - list_directory** (MCP)(path: "/Users/UTN2026/")
Running...(ctrl+b to run in background)

Tool use

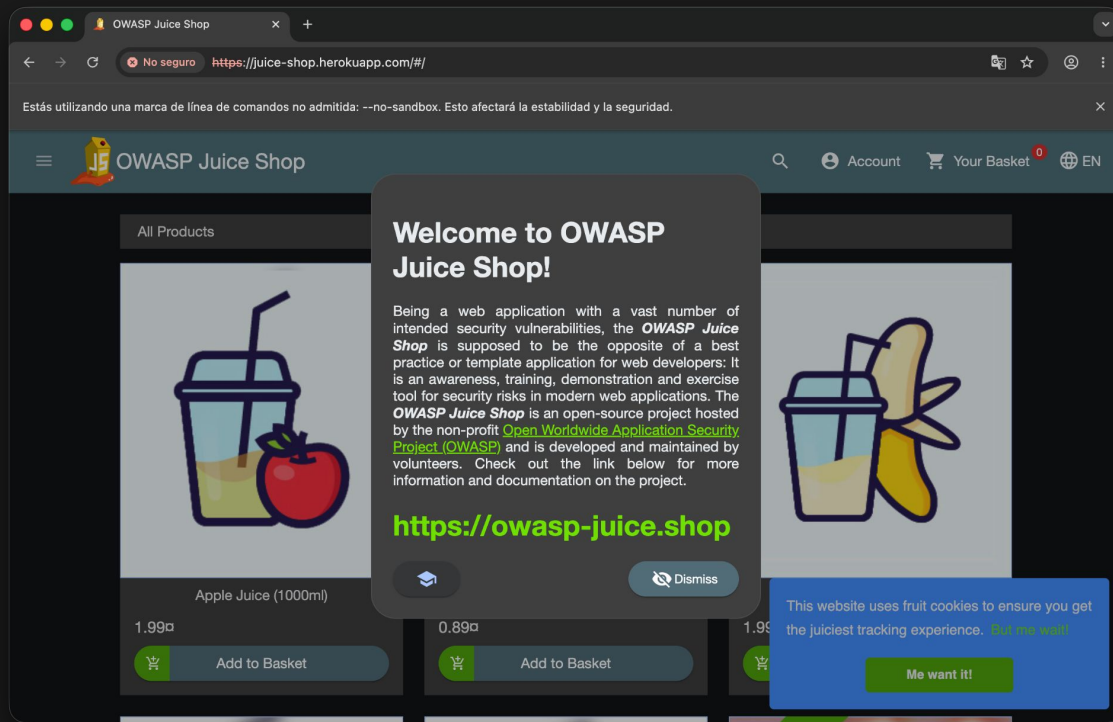
filesystem - list_directory(path: "/Users/UTN2026/") (MCP)
Get a detailed listing of all files and directories in a specified path. Results clearly distinguish between files and directories with [FILE] and [DIR] prefixes. This tool is essential for understanding directory structure and finding specific files within a directory. Only works within allowed directories.

Do you want to proceed?

- 1. Yes
2. Yes, and don't ask again for **filesystem - list_directory** commands in /Users/UTN2026/
3. No

Esc to cancel · Tab to amend

MCP Playwright





Detalles del pensamiento

Called playwright 2 times (ctrl+o to expand)

- The account menu expanded but the dropdown items aren't visible in the partial snapshot. Let me get the full page snapshot to find the menu items.

Called playwright (ctrl+o to expand)

- The account menu shows only "Login" since we're not authenticated. Now I'll use JavaScript to extract all the links from the account dropdown and then navigate each route systematically. Let me navigate to the login page first.

Called playwright (ctrl+o to expand)

- This is an Angular SPA – forms are rendered dynamically and may not use standard `<form>` tags. Let me take a snapshot of the login page to see the actual DOM elements.

Called playwright (ctrl+o to expand)

- I can see the login form clearly. It's Angular-based (no `<form>` tag wrapper but has input fields). I can see:
 - Email textbox
 - Password textbox
 - "Forgot your password?" link -> `#/forgot-password`
 - "Remember me" checkbox
 - "Login with Google" button
 - "Not yet a customer?" -> `#/register`

Let me invoke the form-mapping skill for this login form, then continue navigating.

- **Skill(form-mapping)**
- I'll now write the login form entry to FORM.md.
- Let me check if FORM.md already exists, then create/append to it.

Called filesystem (ctrl+o to expand)

- File doesn't exist yet. I'll create it with the login form entry.

Calling filesystem... (ctrl+o to expand)
(ctrl+b to run in background)

Documentando hallazgos

Preview FORM.md ×

FORM.md — Mapa de Formularios Descubiertos

Target: <https://juice-shop.herokuapp.com/> Agente: web-crawler Sesión: 2026-05-30

Formulario Detectado en: **Login**

- URL Origen: <https://juice-shop.herokuapp.com/#/login>
- Método HTTP: **POST**
- Action URL: </rest/user/login>

Campos Identificados:

Atributo	name	Tipo (type)	Marcador (placeholder)	Requerido	Notas / Propósito Estimado
email	email	email	—	Sí	Input de autenticación / vector SQLi
password	password	password	—	Sí	Contraseña
rememberMe	checkbox	checkbox	—	NO	Persistencia de sesión

Notas: Angular SPA — sin tag `<form>` estándar. También presenta botón Google OAuth (</auth/google>). Enlaza a [#/forgot-password](/forgot-password) y [#/register](/register).

Formulario Detectado en: **User Registration**

- URL Origen: <https://juice-shop.herokuapp.com/#/register>
- Método HTTP: **POST**
- Action URL: </api/Users/>



Iniciando el agente Burp-Analyst



Claude Code v2.1.158
Sonnet 4.6 · Claude Pro
~/Work/UTN2026

Opus 4.8 is now available! · /model to switch

> /clear

└ (no content)

> Utiliza el agente burp-analyst para realizar el reconocimiento

- Lanzando el agente `burp-analyst` para realizar el reconocimiento.
- `burp-analyst`(Reconocimiento con Burp Suite)
 - └ `burp - get_proxy_http_history (MCP)(count: 100, offset: 0)`
Running...
Bash(curl -sI http://juice-shop.herokuapp.com --max-time 10 -L 2>&1)
Running...
... +2 tool uses (ctrl+o to expand)
(ctrl+b to run in background)

Tool use

`burp - get_proxy_http_history(count: 100, offset: 0) (MCP)`
Displays items within the proxy HTTP history

Do you want to proceed?

> 1. Yes

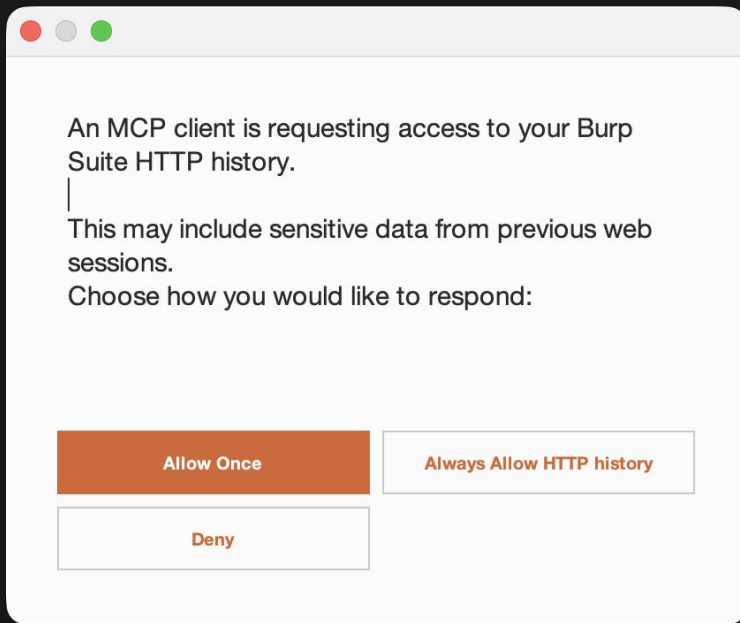
2. Yes, and don't ask again for `burp - get_proxy_http_history` commands in `/Users,`

`/UTN2026`

3. No



Permisos para acceder a Burp





Alimentando PROGRESS.md

```
PROGRESS.md M X
PROGRESS.md > ** ## [2026-05-30 04:32] burp-analyst — Reconocimiento Inicial
1  ## [2026-05-30 04:32] burp-analyst — Reconocimiento Inicial
23  ### Endpoints de API documentados
43  - GET /api/Quantitys/
44  - GET /socket.io/ → WebSocket real-time
45
46  ### Hallazgos de seguridad
47
48  1. **[HIGH] Versión exacta expuesta sin autenticación** - /rest/admin/application-version → {"version":"20.0.0"}
49  2. **[HIGH] Configuración completa de la aplicación pública** - /rest/admin/application-configuration
   expone: baseUrl interno (http://localhost:3000), puerto (3000), Google OAuth client_id, modelo LLM
   (gemma4:e4b), chatbot config
50  3. **[HIGH] CORS incorrecto en Socket.IO** - Access-Control-Allow-Origin: http://localhost:4200 (internal
   dev origin leakeado en producción)
51  4. **[MEDIUM] Endpoint de cambio de contraseña por GET** - /rest/user/change-password?current=&new=&repeat=
   expone credenciales en URL/logs
52  5. **[MEDIUM] Puerto 80 activo sin redirect a HTTPS** - HTTP 503 (dyno dormido), no hay redirect 301
   explícito a HTTPS
53  6. **[MEDIUM] ACAO: * (wildcard) en endpoints de API** - Access-Control-Allow-Origin: * en todos los
   endpoints REST y estáticos
54  7. **[INFO] X-Recruiting header** - X-Recruiting: /#/jobs en todas las respuestas
55  8. **[INFO] Feature-Policy header legacy** - Feature-Policy: payment 'self' (deprecado, debería ser
   Permissions-Policy)
56
57  ### Próximos pasos sugeridos
58
59  - Pruebas de SQLi en /rest/products/search?q=
60  - Autenticación: pruebas de bypass en /rest/user/login
61  - Enumeración de usuarios via /api/Users/
62  - Exploración de endpoints Web3 (/rest/web3/)
63  - Verificar acceso no autenticado a /api/Challenges/ completo
```

Documentando Hallazgos

```
1 # Plantilla de Hallazgo - Informe de Seguridad (OWASP)
2
3 **Titulo:** Endpoints Administrativos Expuestos sin Autenticación – Divulgación de Configuración Completa
4 **Categoría OWASP:** A01:2021 – Broken Access Control / A05:2021 – Security Misconfiguration
5 **Severidad:** Crítica
6
7 **Resumen:**
8 Los endpoints `/rest/admin/application-version` y `/rest/admin/application-configuration` retornan
9 información sensible de la aplicación sin requerir ningún token de sesión ni credencial. Cualquier usuario
10 anónimo puede obtener la versión exacta del software, la configuración interna del servidor, el Client ID
11 de Google OAuth, la URL base interna y el modelo LLM utilizado.
12
13 **Impacto:**
14 - **Reconocimiento facilitado:** La versión exacta (`20.0.0`) permite mapear CVEs conocidos para OWASP
15 Juice Shop sin ningún acceso previo.
16 - **Exposición de OAuth:** El `clientId` de Google OAuth expuesto permite a un atacante construir flujos de
17 OAuth phishing o intentar ataques de token hijacking.
18 - **Fuga de topología interna:** La URL base interna (`http://localhost:3000`) y el puerto del servidor
19 revelan la arquitectura interna de despliegue.
20 - **Fuga de modelo LLM:** El identificador del chatbot (`gemma4:e4b`) puede usarse para identificar
21 vulnerabilidades específicas del modelo.
22
23 **Evidencia (Prueba de Concepto):**
24
25 **Paso 1 – Obtener versión exacta (sin autenticación):**
26 Send Request
27 ```http
28 GET /rest/admin/application-version HTTP/1.1
29 Host: juice-shop.herokuapp.com
30 User-Agent: Mozilla/5.0
31 Accept: application/json
32 ```
```

Referencias

- Repositorio: [https://github.com/artssec/BurpSuite_con MCP y Claude](https://github.com/artssec/BurpSuite_con_MCP_y_Claude) (Nuevo!)
- MCP Burp: <https://github.com/PortSwigger/mcp-server>
- MCP Playwright: <https://github.com/microsoft/playwright-mcp>
- MCP FileSystem: <https://github.com/modelcontextprotocol/servers/tree/main/src/filesystem>
- Sitio oficial MCP: <https://modelcontextprotocol.io>
- MCP Servers: <https://github.com/modelcontextprotocol/servers>
- Agents Claude Code: <https://code.claude.com/docs/en/sub-agents>

Preguntas?



Muchas gracias!

Hugo Ávila

Linkedin: devhugoavila

X @hugok2k

www.hugoavila.dev

Maxi Soler

Linkedin: maxisoler

X @maxisoler

www.artssec.com

